سند رسمی پروژه · نسخه ۲٫۱

سامانه حضور و غیاب رز سفید

سند جامع نیازمندی‌ها، معماری و استقرار

مبتنی بر PWA، Android و Docker؛ زبان فارسی، راست‌به‌چپ و تقویم شمسی

۸,۵۰۰	۸۵۰	۳ ماه	Docker
پرسنل هدف	شعبه و کلینیک	نگهداری جزئیات تردد	استقرار مرکز داده

مخزن کد: github.com/sjalilvand/rose-attendance

اکتبر ۲۰۲۶ · مهر ۱۴۰۵

مشخصات، تاریخچه و فهرست مطالب

مرجع رسمی طراحی، توسعه، آزمون و برآورد پروژه

موضوع	شرح
نسخه سند	۲٫۱
وضعیت	مبنای طراحی، توسعه، آزمون و برآورد پروژه
مقیاس هدف	حدود ۸٬۵۰۰ پرسنل در ۸۵۰ شعبه و کلینیک
محل استقرار	مرکز داده، قابل دسترسی از اینترنت
مخزن کد	`github.com/sjalilvand/rose-attendance`
تاریخ تنظیم	اکتبر ۲۰۲۶ (مهر ۱۴۰۵)

تاریخچه نسخه‌ها

نسخه	شرح تغییر
۱٫۰	نسخه اولیه برداشت نیازمندی‌ها با فرض اجبار GPS (ارجاع تاریخی)
۲٫۰	حذف اجبار GPS، تثبیت ثبت آفلاین از نسخه اول، سیاست حذف سه‌ماهه جزئیات، معماری Docker و مدل پایگاه داده پیشنهادی
۲٫۱	بازبینی و تصویب رسمی ده مورد بخش ۳۴ با تأیید کارفرما؛ ارتقای بخش ۳۴ از «موارد در انتظار تصویب» به «موارد تصویب‌شده»

راهنمای خواندن سند

این سند مبنای رسمی طراحی، توسعه، آزمون و برآورد پروژه است و شامل پنج بخش است: نیازمندی‌های کسب‌وکار، سیاست داده و پایگاه داده، معماری فنی و API، Docker و امنیت و عملیات، و در پایان آزمون، اجرا و تحویل. هر تصمیمی که در سند «قطعی» اعلام شده، مبنای کار تیم فنی است و تغییر آن نیازمند ثبت در نسخه بعدی سند دارد تا مرجع واحد پروژه حفظ بماند. مواردی که پیش از این در بخش ۳۴ صرفاً به‌صورت پیشنهاد فهرست شده بودند، در نسخه ۲٫۱ با تأیید کارفرما به‌صورت قطعی تصویب شده‌اند؛ بخش ۳۴ اکنون فهرست رسمی تصمیمات مصوب است.

در سراسر سند، بلوک‌هایی با عنوان **«پیشنهاد تکمیلی»** آمده است. این بلوک‌ها پیشنهادهای مشخص تیم فنی برای پرکردن خلأهای تصمیم‌گیری هستند. در بازبینی نسخه ۲٫۱، موارد راهبردیِ تجمیع‌شده در جدول بخش ۳۴ با تأیید کارفرما تصویب شده‌اند و عنوان بلوک مرتبط در متن به «تصمیم مصوب (نسخه ۲٫۱)» تغییر یافته است؛ سایر بلوک‌ها تا زمان ثبت در نسخه بعدی سند، جنبه پیشنهادی خود را حفظ می‌کنند و مبنای کد قرار نمی‌گیرند.

فهرست مطالب

بخش اول ـ نیازمندی‌های کسب‌وکار

۱. تصمیم‌های قطعی و فرض سند
۲. هدف سامانه
۳. نقش‌ها و سطح دسترسی
۴. مدیریت شعب و کلینیک‌ها
۵. مدیریت پرسنل چندشعبه‌ای
۶. ورود کاربران و مدیریت حساب
۷. سیاست دقیق ثبت تردد
۸. تردد ناقص و اصلاحات
۹. ثبت آفلاین و همگام‌سازی
۱۰. شیفت و محاسبه کارکرد
۱۱. مرخصی و مأموریت
۱۲. پیام‌رسانی
۱۳. گزارش‌ها و بستن ماه
۱۴. ورود اطلاعات از Excel

بخش دوم ـ سیاست داده و پایگاه داده

۱۵. سیاست حذف سه‌ماهه
۱۶. ساختار پیشنهادی پایگاه داده

بخش سوم ـ معماری فنی و Docker

۱۷. فناوری پیشنهادی
۱۸. سرویس‌های Docker
۱۹. ساختار پیشنهادی مخزن
۲۰. نمونه Dockerfile بک‌اند
۲۱. نمونه Dockerfile وب و PWA
۲۲. نمونه Docker Compose
۲۳. تنظیم Nginx
۲۴. تنظیمات محیط
۲۵. روال استقرار

بخش چهارم ـ API، امنیت و عملیات

۲۶. APIهای اصلی
۲۷. امنیت
۲۸. پشتیبان‌گیری و بازیابی
۲۹. پایش و ظرفیت
۳۰. کار پاکسازی خودکار

بخش پنجم ـ آزمون، اجرا و تحویل

۳۱. معیارهای پذیرش نسخه اول
۳۲. فازهای اجرا
۳۳. اقلام تحویل
۳۴. موارد تصویب‌شده (نسخه ۲٫۱)

پیوست‌ها

جمع‌بندی اجرایی
واژه‌نامه
پیوست ـ نگاشت فایل‌های مخزن به سند

مبانی تصمیم‌گیری

۱. تصمیم‌های قطعی و فرض سند

این سند جایگزین برداشت‌های قبلی درباره اجبار GPS می‌شود. تمامی تصمیم‌هایی که در جدول زیر ثبت شده‌اند، نتیجه هماهنگی‌های نهایی با کارفرما هستند و مبنای طراحی، تخمین حجم کار و قرارداد توسعه قرار می‌گیرند. هرگونه تغییر در این تصمیم‌ها باید در قالب ویرایش جدید این سند و با ثبت در تاریخچه نسخه‌ها انجام شود تا مرجع واحد پروژه حفظ بماند.

۱.۱. نیازمندی‌های تأییدشده

موضوع	تصمیم
کاربران	حدود ۸٬۵۰۰ نفر
شعب	حدود ۸۵۰ شعبه و کلینیک
نرم‌افزار پرسنل	Android و PWA
نرم‌افزار مدیران	پنل وب
زبان و ظاهر	فارسی، راست‌به‌چپ، تقویم شمسی
برنامه کاری	شیفت ثابت و چرخشی
فعالیت چندشعبه‌ای	مجاز

موضوع	تصمیم
مرخصی و مأموریت	تأیید تک‌مرحله‌ای توسط مدیر شعبه مربوط
ارتباط آنلاین	پیام
ثبت آفلاین	در نسخه اول
ثبت بدون GPS	مجاز، بدون نیاز به تأیید مدیر
ورود اطلاعات اولیه	Excel
اتصال حقوق و دستمزد	خارج از محدوده فعلی
میزبانی	مرکز داده تحت اینترنت
استقرار	Docker
نگهداری جزئیات تردد، موقعیت و پیام	سه ماه

۱.۲. فرض درباره خلاصه کارکرد

در آخرین پیام، موضوع باقی‌ماندن خلاصه کارکرد ماهانه مطرح شده، اما پاسخ صریح «بله» یا «خیر» ذکر نشده است. این سند با فرض حفظ خلاصه کارکرد ماهانه و حذف جزئیات تردد، موقعیت و پیام پس از سه ماه تنظیم شده است. این فرض باید قبل از فعال‌سازی حذف خودکار تأیید شود.

مدت نگهداری خلاصه‌ها، درخواست‌های مرخصی و مأموریت و سوابق مالی مرتبط نیز باید مستقل از دوره سه‌ماهه مشخص شود. تا زمان تصویب، پاکسازی خودکار فقط برای داده‌های جزئی فعال می‌شود و خلاصه‌های کارکرد در هیچ سناریویی حذف نمی‌شوند.

> **پیشنهاد تکمیلی (نیازمند تأیید):** برای خلاصه‌های قطعی کارکرد و سوابق درخواست‌های مرخصی و مأموریت، نگهداری حداقل دوساله پیشنهاد می‌شود؛ این بازه با چرخه‌های حسابرسی سالانه و رسیدگی به ادعاهای پایان خدمت سازگار است. مدت دقیق باید با واحد حقوق و دستمزد و مشاور قانونی نهایی شود.

بخش اول

نیازمندی‌های کسب‌وکار

بخش‌های ۲ تا ۱۴ ـ از هدف سامانه تا ورود اطلاعات از Excel

۲. هدف سامانه

هدف، ایجاد سامانه‌ای مرکزی برای موارد زیر است:

- مدیریت اطلاعات شعب و پرسنل.
- برنامه‌ریزی شیفت‌های ثابت و چرخشی.
- ثبت ورود و خروج از Android و PWA.
- ثبت تردد با موقعیت یا بدون موقعیت.
- ثبت موقت هنگام قطع اینترنت و همگام‌سازی بعدی.
- مدیریت مرخصی و مأموریت.
- محاسبه کارکرد روزانه و ماهانه.
- پیام‌رسانی مدیر و پرسنل.
- تهیه گزارش‌های شعبه‌ای، منطقه‌ای و سازمانی.
- نگهداری خلاصه کارکرد و اجرای سیاست حذف اطلاعات جزئی.

این سامانه ابزار سنجش «زمان» است، نه ابزار قضاوت عملکرد شغلی. حضور طولانی‌تر الزاماً به معنای عملکرد بهتر نیست و سامانه نباید به‌عنوان ابزار ارزیابی کیفیت کار تفسیر شود. این تفکیک باید در آموزش مدیران و پرسنل نیز شفاف شود تا انتظارات غیرواقعی شکل نگیرد.

خارج از محدوده نسخه اول

- محاسبه حقوق و دستمزد.
- تماس صوتی و تصویری.
- تشخیص چهره.
- اتصال به دستگاه حضور و غیاب.
- ردیابی دائمی پرسنل.
- ارزیابی کیفیت عملکرد شغلی.

پیشنهاد تکمیلی: مرزهای فوق در قرارداد توسعه و اسناد آموزشی به‌صورت صریح تکرار شود تا درخواست‌های جدید (مانند اتصال به دستگاه‌های حضور و غیاب یا حقوق و دستمزد) از مسیر تغییر سند و برآورد مجدد عبور کنند، نه از مسیر انتظار ضمنی کاربران.

۳. نقش‌ها و سطح دسترسی

نقش	اختیارات
پرسنل	ثبت تردد، مشاهده اطلاعات خود، ثبت درخواست، ارسال پیام
مدیر شعبه	مشاهده اطلاعات مرتبط با شعبه، تأیید درخواست‌ها، بررسی اصلاح تردد
مدیر منطقه	مشاهده شعب مجاز زیرمجموعه و گزارش‌های منطقه
منابع انسانی	مدیریت پرونده‌ها، قواعد کاری، مانده مرخصی و بستن دوره
مدیر سامانه	تنظیمات فنی، حساب‌ها و مجوزها
حسابرس	مشاهده اطلاعات مجاز بدون امکان تغییر

یک نفر می‌تواند هم‌زمان چند نقش داشته باشد (برای مثال مدیر شعبه که خود پرسنل نیز هست)؛ اما اختیارات هر نقش باید جداگانه اعمال و جداگانه ثبت شود تا در گزارش‌های حسابرسی مشخص باشد هر اقدام با کدام نقش انجام شده است. ترکیب نقش‌ها نباید راهی برای دور زدن قاعده «تأیید نکردن درخواست خود» ایجاد کند.

قواعد الزامی

- کنترل دسترسی در API و سرور انجام شود.
- مخفی‌کردن منو جایگزین کنترل دسترسی نیست.
- مدیر شعبه فقط ترددها و درخواست‌های مربوط به شعبه مجاز خود را ببیند.
- دسترسی به اطلاعات حساس پرسنل بر اساس مجوز مستقل باشد.
- مدیر نتواند درخواست خودش را تأیید کند؛ برای این حالت جانشین تعیین شود.
- تغییر دسترسی‌ها و تعیین جانشین ثبت حسابرسی داشته باشد.
- انتقال کارمند، دسترسی مدیر قبلی به اطلاعات نامرتبط جدید را ایجاد نکند.

پیشنهاد تکمیلی — ماتریس دسترسی پیش‌فرض: هر نقش با سه سطح «هیچ / مشاهده / اقدام» روی چهار حوزه اصلی تعریف شود: تردد (پرسنل: اقدام روی خود؛ مدیر شعبه: مشاهده شعبه و اقدام اصلاحی؛ منابع انسانی: مشاهده همه؛ حسابرس: فقط مشاهده)، درخواست‌ها، گزارش‌ها و تنظیمات سامانه. این ماتریس به‌صورت داده در جداول `roles` و `permissions` نگهداری و از طریق پنل مدیر سامانه قابل ویرایش باشد تا هر تغییر مجوز بدون انتشار نسخه جدید نرم‌افزار اعمال شود.

۴. مدیریت شعب و کلینیک‌ها

اطلاعات هر شعبه

- شناسه داخلی و کد یکتا.
- نام.
- استان، شهر و منطقه.
- آدرس و تلفن.
- مدیر و جانشین.
- مختصات جغرافیایی.
- شعاع مجاز ثبت مکانی.
- وضعیت فعال یا غیرفعال.
- تاریخ شروع و پایان فعالیت.
- تقویم کاری.

هر شعبه باید بتواند بدون قطع فعالیت، مشخصات مکانی و مدیریتی خود را به‌روزرسانی کند. تغییر مدیر یا جانشین نباید به درخواست‌های در جریان آسیب بزند؛ درخواست‌های ارسالی به مدیر قبلی باید به مدیر یا جانشین جدید منتقل شوند و این انتقال ثبت شود.

قواعد مکانی

- شعاع مجاز برای هر شعبه قابل تنظیم باشد.
- مقدار شعاع با شرایط واقعی شعبه تعیین شود.
- تغییر مختصات و شعاع ثبت حسابرسی داشته باشد.
- وجود چند نقطه مجاز برای یک شعبه، در صورت نیاز، قابل توسعه باشد.

چون ثبت بدون GPS مجاز است، کنترل محدوده ابزار گزارش و کنترل موقعیت است، نه شرط همیشگی ثبت حضور. بنابراین دقت نقاط و شعاع‌ها بر کیفیت گزارش‌های مدیریتی اثر دارد، اما هیچ‌گاه نباید به بهانه دقت موقعیت، ثبت تردد متوقف یا مشروط شود.

> **تصمیم مصوب (نسخه ۲٫۱):** شعاع پیش‌فرض ۱۵۰ متر برای شعب شهری و ۳۰۰ متر برای کلینیک‌ها و سایت‌های بزرگ با تأیید کارفرما تصویب شد؛ این مقادیر باید به‌ازای هر شعبه با بازدید محلی تنظیم و در پنل منابع انسانی ثبت شوند. حداقل و حداکثر مجاز شعاع (بین ۵۰ تا ۱٬۰۰۰ متر) نیز در تنظیمات سامانه محدود می‌شود تا خطای ورود داده کنترل گردد.

۵. مدیریت پرسنل چندشعبه‌ای

اطلاعات پرونده

- کد پرسنلی یکتا.
- نام و نام خانوادگی.
- موبایل.
- کد ملی، در صورت ضرورت سازمانی.
- سمت.
- وضعیت همکاری.
- تاریخ شروع و پایان همکاری.
- شعبه اصلی.
- شعب مجاز.
- مدیر مستقیم.

- برنامه کاری.

ارتباط پرسنل و شعب

ارتباط باید تاریخ‌دار باشد:

```
پرسنل ← شعبه ← تاریخ شروع ← تاریخ پایان ← وضعیت مجاز
```

قواعد

- یک نفر می‌تواند در چند شعبه فعالیت کند.
- هر تردد به یک شعبه مشخص تعلق دارد.
- هر شیفت به پرسنل، شعبه و بازه زمانی مشخص متصل است.
- شیفت‌های هم‌پوشان فرد کنترل شوند.
- حضور هم‌زمان معتبر در دو شعبه ایجاد نشود.
- انتقال بین شعب، گزارش‌های تاریخی را تغییر ندهد.

درخواست‌های چندشعبه‌ای

اگر مرخصی یا مأموریت چند شیفت در شعب متفاوت را پوشش دهد:

- درخواست به بخش‌های مرتبط با هر شعبه تفکیک شود.
- مدیر هر شعبه قسمت مربوط را تأیید کند.
- وضعیت کلی درخواست مشخص باشد.
- زمان‌ها و مانده مرخصی دوباره محاسبه نشوند.

تفکیک درخواست چندشعبه‌ای باید به‌گونه‌ای انجام شود که رد یا تأیید یک بخش، وضعیت بخش‌های دیگر را تغییر ندهد؛ وضعیت کلی درخواست صرفاً ترکیب وضعیت بخش‌ها است. اگر بخشی از درخواست بدون تصمیم بماند، فقط همان بخش در صف رسیدگی مدیر شعبه مربوط نمایش داده می‌شود.

۶. ورود کاربران و مدیریت حساب

پیشنهاد نسخه اول

- ورود با شناسه پرسنلی یا موبایل و رمز عبور.
- بازیابی رمز از طریق روش تأییدشده سازمان.
- احراز هویت چندمرحله‌ای برای مدیران حساس.
- ثبت نشست‌ها و امکان خروج از دستگاه‌های قبلی.

اگر ورود یا بازیابی با پیامک انتخاب شود، تأمین‌کننده پیامک و هزینه آن وابستگی خارجی پروژه محسوب می‌شود. در این حالت باید سرویس جایگزین برای قطعی ارائه‌دهنده، سقف هزینه پیامک و سیاست نگهداری شماره موبایل‌ها نیز پیش از توسعه مشخص شود.

قواعد

- کد ملی رمز عبور نیست.
- رمزها با الگوریتم مناسب هش شوند.
- تلاش ناموفق ورود محدود شود.
- پس از پایان همکاری، ورود فرد مسدود شود.
- برای استفاده آفلاین، کاربر باید قبلاً دستگاه را در حالت آنلاین آماده کرده باشد.
- ثبت رویداد آفلاین، دسترسی نامحدود به حساب مسدودشده ایجاد نکند.

قاعده آخر حساس است: رویداد آفلاینِ همگام‌شده پس از مسدودسازی حساب باید در صف رسیدگی قرار گیرد و در محاسبات فقط پس از تأیید منابع انسانی لحاظ شود. علاوه بر آن، مسدودسازی حساب نباید داده‌های محلی روی دستگاه را نابود کند؛ فقط اجازه ثبت و ارسال جدید را بگیرد.

پیشنهاد تکمیلی — سیاست پیش‌فرض حساب و نشست: حداقل طول رمز ۸ کاراکتر با ترکیب حرف و رقم، هش با Argon2id (یا bcrypt در صورت محدودیت زیرساخت)، قفل تدریجی پس از ۵ تلاش ناموفق (پنج دقیقه برای تلاش‌های اول و افزایش پله‌ای)، عمر توکن دسترسی ۱۵ دقیقه و توکن تمدید ۷ روز، و امکان «خروج از همه دستگاه‌ها» در پروفایل کاربر پیشنهاد می‌شود. فهرست نشست‌های فعال با نوع دستگاه و آخرین استفاده، حداقل ۹۰ روز نگهداری شود.

۷. سیاست دقیق ثبت تردد

۷.۱. اصل اساسی

ثبت بدون GPS مجاز است و تأیید مدیر نمی‌خواهد. بنابراین این موارد نباید باعث اجبار به تأیید مدیر شوند:

- خاموش‌بودن خدمات مکان.
- ندادن مجوز موقعیت توسط کاربر.
- دریافت‌نشدن موقعیت.
- خطای سرویس موقعیت‌یابی.

با این حال، ثبت بدون موقعیت باید از ثبت همراه موقعیت قابل تشخیص باشد. هدف این تفکیک، شفافیت گزارش‌های مدیریتی است: مدیر باید بداند چه سهمی از ثبت‌ها بدون موقعیت انجام شده است، بدون اینکه برای کاربر مانعی ایجاد شود.

۷.۲. اطلاعات رویداد

فیلد	شرح
شناسه رویداد	یکتا
پرسنل	صاحب رویداد
شعبه	شعبه منتخب یا مربوط به شیفت
نوع	ورود یا خروج
زمان دستگاه	برای بررسی رویداد آفلاین
زمان دریافت سرور	مرجع دریافت
زمان مؤثر	زمان پذیرفته‌شده برای محاسبه
روش ثبت	Android یا PWA
حالت اتصال	آنلاین یا آفلاین
مختصات	اختیاری
دقت و زمان موقعیت	اختیاری
وضعیت موقعیت	در محدوده، خارج محدوده، ناموجود، کم‌دقت
علت نبود موقعیت	در صورت قابل تشخیص بودن
وضعیت رویداد	پذیرفته، نیازمند رسیدگی یا رد فنی
کلید جلوگیری از تکرار	برای ارسال مجدد

وجود مختصات به معنی تأیید قطعی حضور نیست. بهتر است به‌جای نامی مانند `is_gps_verified` از وضعیت‌های روشن موقعیت استفاده شود تا معنای داده در کد و گزارش‌ها ابهام نداشته باشد.

پیشنهاد تکمیلی — مقادیر پیش‌فرض وضعیت‌ها: وضعیت موقعیت با چهار مقدار `UNAVAILABLE`، `OUT_OF_RANGE`، `IN_RANGE` و `LOW_ACCURACY` و وضعیت رویداد با سه مقدار `NEEDS_REVIEW`، `ACCEPTED` و `REJECTED_TECHNICAL` تعریف شود. «رد فنی» فقط برای خطاهای ساختاری (مانند شعبه نامعتبر یا رویداد تکراری) استفاده می‌شود و هیچ‌گاه برای نبود موقعیت یا خارج محدوده بودن آن به‌کار نمی‌رود.

۷.۳. فرایند ثبت

1. شناسایی کاربر.
2. تعیین شعبه مجاز.
3. درخواست موقعیت در صورت امکان.
4. ادامه ثبت حتی در نبود موقعیت.
5. بررسی ترتیب ورود و خروج.
6. ذخیره رویداد.
7. نمایش رسید و وضعیت.

دریافت موقعیت نباید کاربر را برای مدت طولانی معطل کند. پس از مهلت تعریف‌شده، ثبت بدون موقعیت ادامه یابد. رابط کاربری باید در همین حالت صادقانه وضعیت را نشان دهد: «ثبت شد؛ موقعیت دریافت نشد» تا کاربر نداند چرا برچسب موقعیت در گزارش وجود ندارد.

پیشنهاد تکمیلی: مهلت انتظار موقعیت ۵ ثانیه با امکان یک تلاش مجدد پیشنهاد می‌شود؛ پس از آن ثبت بدون موقعیت انجام و علت قابل‌تشخیص (عدم مجوز، خاموش بودن سرویس مکان یا خطای سرویس) در رویداد ذخیره می‌شود.

۷.۴. موقعیت خارج از محدوده

پیشنهاد سازگار با سیاست سازمان:

- تردد ثبت شود.
- با برچسب «خارج از محدوده» مشخص شود.
- در گزارش مدیریتی قابل مشاهده باشد.
- صرف این برچسب، تردد را به درخواست تأیید مدیر تبدیل نکند.

این قاعده باید پیش از توسعه تصویب شود؛ زیرا ردکردن تردد خارج محدوده در حالی که ثبت بدون موقعیت مجاز است، کنترل قابل اتکایی ایجاد نمی‌کند. کاربری که می‌تواند با خاموش‌کردن موقعیت ثبت کند، با رد شدن ثبت خارج محدوده فقط تشویق می‌شود موقعیت را خاموش کند و ارزش کنترلی صفر خواهد بود.

۷.۵. کنترل‌های باقی‌مانده

مجاز بودن ثبت بدون GPS به معنی حذف سایر کنترل‌ها نیست:

- کاربر باید معتبر باشد.
- شعبه باید برای فرد مجاز باشد.
- ورودهای هم‌زمان کنترل شوند.
- درخواست تکراری اثر دوباره نداشته باشد.
- خروج بدون ورود و تردد ناقص بررسی شوند.
- اصلاح زمان، فرایندی مستقل داشته باشد.

۸. تردد ناقص و اصلاحات

موارد نیازمند رسیدگی

- ورود بدون خروج.
- خروج بدون ورود.

- چند ورود پشت سر هم.
- تداخل حضور در دو شعبه.
- ترتیب نامعتبر رویدادهای آفلاین.
- درخواست تغییر ساعت گذشته.

اصلاح تردد

- پرسنل درخواست اصلاح ثبت کند.
- مدیر شعبه مربوط بررسی کند.
- مقدار اصلی، مقدار اصلاح‌شده، دلیل و تصمیم ثبت شوند.
- رویداد اصلی تا پایان دوره نگهداری بازنویسی یا ناپدید نشود.

اصلاح تردد باید همیشه «افزودن لایه تصمیم» باشد، نه «تغییر تاریخچه». گزارش‌های میانی رویداد اصلی را نشان می‌دهند و محاسبات کارکرد از آخرین تصمیم اصلاحی پیروی می‌کنند؛ به این ترتیب هم شفافیت حفظ می‌شود و هم نتیجه محاسبات قطعی است.

تأیید اصلاح تردد با تأیید ثبت بدون GPS متفاوت است؛ ثبت بدون GPS تأیید نمی‌خواهد. اصلاح فقط برای تصحیح زمان، شعبه یا جفت‌کردن رویدادهای ناقص است و نیازمند دلیل و تصمیم مدیر است.

۹. ثبت آفلاین و همگام‌سازی

۹.۱. داده‌های لازم روی دستگاه

- شناسه کاربر.
- شعب مجاز.
- شیفت‌های نزدیک.
- آخرین وضعیت همگام‌شده تردد.
- نسخه قواعد موردنیاز.
- صف رویدادهای ارسال‌نشده.

حداقل داده لازم ذخیره شود؛ کل اطلاعات سازمان روی گوشی قرار نگیرد. حجم داده‌های محلی باید به‌قدری کوچک باشد که پاک‌کردن آن در از دست رفتن اطلاعات سازمانی خطر ایجاد نکند و تنها نتیجه آن، نیاز به ورود مجدد و دریافت داده پایه باشد.

۹.۲. رویداد آفلاین

هر رویداد شامل موارد زیر باشد:

- UUID تولیدشده روی دستگاه.
- شناسه کاربر و شعبه.
- نوع رویداد.
- زمان دستگاه.
- اطلاعات موقعیت، اگر موجود باشد.
- نسخه برنامه.
- شماره ترتیب محلی.
- زمان آخرین ارتباط معتبر با سرور.

ثبت بدون GPS در حالت آفلاین نیز مجاز است. شماره ترتیب محلی برای تشخیص ترتیب واقعی رویدادهای یک دستگاه است و سرور از آن فقط برای تحلیل استفاده می‌کند؛ جفت‌کردن ورود و خروج صرفاً بر اساس این شماره انجام نمی‌شود.

۹.۳. همگام‌سازی

- ارسال مجدد با همان شناسه انجام شود.
- سرور شناسه‌های دریافت‌شده را تشخیص دهد.
- نتیجه هر رویداد جداگانه بازگردد.
- قطع ارتباط وسط ارسال باعث گم‌شدن یا ثبت دوباره نشود.
- رویدادها صرفاً بر اساس ترتیب رسیدن به سرور جفت نشوند.
- تعارض بین دو دستگاه بررسی شود.

همگام‌سازی باید «دست‌کم یک‌بار و بدون تکرار اثر» باشد: اگر پاسخ سرور به دلیل قطعی به دستگاه نرسد، دستگاه همان رویداد را دوباره می‌فرستد و سرور با تشخیص شناسه، همان نتیجه قبلی را بازمی‌گرداند. این رفتار باید در آزمون‌ها به‌صراحت پوشش داده شود.

> **پیشنهاد تکمیلی — اندازه دسته همگام‌سازی:** ارسال دسته‌ای با حداکثر ۱۰۰ رویداد در هر درخواست و پاسخ به‌ازای هر رویداد به‌صورت جداگانه پیشنهاد می‌شود. اگر تعداد صف بیشتر باشد، دستگاه حلقه ارسال را تا خالی‌شدن صف تکرار می‌کند و برای جلوگیری از اشباع شبکه، بین دسته‌ها فاصله کوتاه (مثلاً دو ثانیه) قرار می‌گیرد.

۹.۴. زمان دستگاه

زمان گوشی قابل تغییر است. بنابراین:

- زمان محلی و زمان دریافت سرور جدا ذخیره شوند.
- تغییر غیرعادی ساعت یا فاصله زیاد آفلاین علامت‌گذاری شود.
- رویداد مشکوک بدون توضیح از کارکرد حذف نشود.
- قواعد رسیدگی به اختلاف زمان قابل تنظیم باشد.

حداکثر تأخیر معمول همگام‌سازی ۷ روز است؛ رویدادهای دیرتر وارد وضعیت رسیدگی می‌شوند (تصویب‌شده در نسخه ۲٫۱).

> **تصمیم مصوب (نسخه ۲٫۱) — آستانه‌های علامت‌گذاری زمان:** اختلاف زمان دستگاه با سرور بیشتر از ±۵ دقیقه در لحظه ثبت، پرچم `CLOCK_SKEW` روی رویداد بگذارد. رویداد آفلاینِ با فاصله آفلاین‌بودن بیش از ۷ روز وارد وضعیت `NEEDS_REVIEW` شود و زمان مؤثر آن فقط با تصمیم مدیر یا منابع انسانی تثبیت گردد. این دو آستانه در تنظیمات سامانه قابل تغییر باشند.

۹.۵. Android و PWA

Android:

- ذخیره محلی کنترل‌شده.
- تلاش همگام‌سازی با ابزار مناسب سیستم‌عامل.
- استفاده از فضای امن برای اطلاعات حساس.
- نمایش تعداد رویدادهای ارسال‌نشده.

PWA:

- بارگذاری اولیه به اینترنت نیاز دارد.
- همگام‌سازی هنگام بازشدن برنامه و بازگشت ارتباط انجام شود.
- ارسال پس‌زمینه در همه مرورگرها تضمین نمی‌شود.
- پاک‌کردن داده‌های مرورگر می‌تواند اطلاعات ارسال‌نشده را حذف کند.
- به‌روزرسانی Service Worker نباید صف آفلاین را پاک کند.
- داده‌های شخصی API به‌صورت عمومی در کش Service Worker ذخیره نشوند.

تفاوت بسترها باید در آموزش کاربران شفاف باشد: در Android ثبت آفلاین پایدار است، اما در PWA مسئولیت حفظ صف تا حدی به کاربر و مرورگر است. برای کاهش ریسک، PWA باید پیش از پاک‌شدن صف، هشدار واضح به کاربر نشان دهد و امکان نمایش «رویدادهای در انتظار ارسال» را فراهم کند.

۱۰. شیفت و محاسبه کارکرد

انواع شیفت

- ثابت.
- چرخشی.
- شب.
- چندبازه‌ای.
- شیفت استثنایی برای تاریخ مشخص.

اطلاعات شیفت

- کد و نام.
- شروع و پایان.
- عبور از نیمه‌شب.
- مدت و نحوه کسر استراحت.
- مهلت مجاز تأخیر.
- قواعد تعجیل.
- تاریخ اعتبار.
- شعبه یا دامنه کاربرد.

الگوی چرخشی

امکان تعریف الگویی مانند:

```
روز اول: صبح
روز دوم: عصر
روز سوم: استراحت
تکرار از تاریخ مشخص
```

تغییر برنامه باید نسخه‌دار باشد و گزارش تاریخی را خودکار تغییر ندهد. هر تغییر الگو یا تخصیص شیفت از تاریخ مشخصی اعمال می‌شود و محاسبات هر ماه با «نسخه برنامه معتبر در همان تاریخ» انجام می‌گیرد.

محاسبات

- ساعات موظفی.
- حضور معتبر.
- کارکرد قابل قبول.
- تأخیر.
- تعجیل.
- غیبت.
- کسری کار.
- مرخصی.
- مأموریت.
- اضافه‌کاری تأییدشده.

زمان‌ها در دیتابیس با واحد دقیق مانند ثانیه ذخیره و در گزارش به ساعت و دقیقه نمایش داده شوند.

اصول

- حضور، مرخصی و مأموریت هم‌پوشان دوباره‌شماری نشوند.
- اضافه‌کاری صرفاً از اختلاف خروج و پایان شیفت نتیجه‌گیری نشود.
- تردد ناقص حضور کامل محسوب نشود.
- شیفت شب بر اساس تاریخ شروع شیفت مدیریت شود.
- شیفت برنامه‌ریزی‌نشده، مسیر مشخص رسیدگی داشته باشد.

قواعد ارفاق، استراحت، اضافه‌کاری و تعطیلات باید از منابع انسانی دریافت شوند. موتور محاسبه باید به‌گونه‌ای طراحی شود که این قواعد به‌صورت داده و با نسخه‌بندی وارد شوند، نه در کد ثابت؛ در غیر این صورت هر تغییر آیین‌نامه کاری نیازمند تغییر نرم‌افزار خواهد بود.

۱۱. مرخصی و مأموریت

مرخصی

انواع قابل تعریف:

- استحقاقی.
- استعلاجی.
- بدون حقوق.
- ساعتی و روزانه.
- انواع اختصاصی شرکت.

اطلاعات درخواست:

- نوع.
- شروع و پایان.
- شیفت‌ها و شعب مرتبط.
- مدت محاسبه‌شده.
- توضیح.
- پیوست در صورت نیاز.
- وضعیت و تصمیم مدیر.

مأموریت

- مقصد یا شعبه مقصد.
- موضوع.
- شروع و پایان.
- مدت محاسبه‌شده.
- مدیر تأییدکننده.
- گزارش پایان، در صورت نیاز.

گردش تأیید

```
پیش‌نویس → ارسال → تأیید یا رد مدیر شعبه
```

قواعد مشترک

- درخواست هم‌پوشان کنترل شود.
- کسر مرخصی از مانده فقط پس از تأیید انجام شود.
- لغو تأییدشده نیازمند ثبت تصمیم باشد.
- تصمیم تکراری مدیر اثر دوباره ایجاد نکند.
- مرخصی و مأموریت خارج برنامه کاری طبق قواعد مصوب محاسبه شوند.
- سوابق این درخواست‌ها خودکار مشمول حذف سه‌ماهه تردد نشوند.

گردش تأیید تک‌مرحله‌ای است، اما ثبت تصمیم باید شامل زمان، تصمیم‌گیرنده و توضیح اختیاری باشد تا در رسیدگی‌های بعدی قابل استناد باشد. در غیاب مدیر، جانشین تعیین‌شده همان اختیار را با هویت خودش اعمال می‌کند و ثبت حسابرسی نشان می‌دهد تصمیم به نیابت از چه کسی گرفته شده است.

۱۲. پیام‌رسانی

امکانات نسخه اول

- پیام مستقیم مدیر و پرسنل مجاز.
- اعلان نتیجه درخواست‌ها.
- درخواست اعلام وضعیت.
- وضعیت ارسال و خوانده‌شدن.
- صفحه مکالمات.

برای کاهش حجم و پیچیدگی، پیوست پیام در نسخه اول اختیاری و خارج از حداقل تحویل در نظر گرفته می‌شود؛ در صورت نیاز باید نوع، حجم و سیاست حذف فایل تعیین شود.

قواعد

- گیرندگان بر اساس مجوز سرور کنترل شوند.
- قطع ارتباط نباید پیام را تکراری کند.
- اتصال لحظه‌ای از طریق WebSocket قابل پیاده‌سازی باشد.
- پیام‌ها پس از سه ماه حذف شوند.
- اعلان حذف‌شده نباید متن پیام قدیمی را نگه دارد.
- وضعیت آنلاین، حضور فیزیکی را اثبات نمی‌کند.

حذف پیام پس از سه ماه باید کامل باشد: متن پیام، وضعیت خوانده‌شدن و اعلان‌های مرتبط با هم پاک شوند و فقط شمارنده‌های آماری کلی (در صورت نیاز) بدون محتوا باقی بمانند. اگر پیام‌رسانی برای اطلاع‌رسانی‌های رسمی استفاده می‌شود، کارفرما باید بداند این کانال جایگزین بایگانی اداری نیست.

۱۳. گزارش‌ها و بستن ماه

داشبورد پرسنل

- شیفت امروز.
- آخرین وضعیت تردد.
- رویدادهای ارسال‌نشده.
- مرخصی و مأموریت.
- کارکرد ماهانه.
- پیام‌ها.

داشبورد مدیر شعبه

- حاضر بر اساس آخرین تردد معتبر.
- ترددهای ناقص.
- افراد بدون ثبت متناسب با شیفت.
- درخواست‌های در انتظار تصمیم.
- ثبت‌های بدون موقعیت و خارج محدوده.
- زمان آخرین همگام‌سازی.

داشبورد نباید اطلاعات آفلاینِ دریافت‌نشده را حضور لحظه‌ای قطعی نشان دهد. برای هر فرد وضعیت نمایشی باید یکی از حالت‌های «حاضر»، «خارج» یا «نامشخص ـ در انتظار همگام‌سازی» باشد و حالت سوم با برچسب روشن از دو حالت دیگر تفکیک شود.

خلاصه ماهانه

برای هر پرسنل و شعبه:

- ماه و سال.
- ساعات موظفی.
- حضور و کارکرد قابل قبول.
- تأخیر و تعجیل.
- غیبت و کسری کار.
- مرخصی به تفکیک نوع.
- مأموریت.
- اضافه‌کاری تأییدشده.
- تعداد تردد ناقص.
- تعداد ثبت بدون موقعیت.
- تعداد ثبت خارج محدوده.
- نسخه قواعد محاسبه.
- وضعیت موقت یا قطعی.

خلاصه کل فرد نیز بدون دوباره‌شماری بین شعب تولید شود؛ یعنی خلاصه کل باید از جمع بخش‌های شعبه‌ای قابل بازسازی باشد تا اختلاف اعداد در بررسی‌ها رخ ندهد.

بستن دوره

1. محاسبه اولیه.
2. رسیدگی به تردد ناقص.
3. تکمیل تصمیم درخواست‌ها.
4. کنترل منابع انسانی.
5. بستن دوره.
6. ثبت نسخه قطعی.

اصلاح بعدی باید نسخه جدید و دلیل داشته باشد؛ نسخه قبلی بی‌ردپا جایگزین نشود. بستن دوره شرط لازم برای پاکسازی امن داده‌های همان دوره است؛ تا دوره‌ای بسته نشده، رویدادهای آن مشمول حذف خودکار نمی‌شوند.

۱۴. ورود اطلاعات از Excel

قالب‌ها

فایل	ستون‌های اصلی
شعب	کد، نام، استان، شهر، آدرس، مختصات، شعاع
پرسنل	کد پرسنلی، نام، موبایل، سمت، وضعیت
انتساب شعبه	کد پرسنلی، کد شعبه، تاریخ شروع و پایان
شیفت‌ها	کد شیفت، شروع، پایان، استراحت
برنامه کاری	پرسنل، شعبه، تاریخ، کد شیفت
مانده اولیه مرخصی	پرسنل، نوع، مقدار، تاریخ مبنا

فرایند بارگذاری

```
بارگذاری → بررسی → پیش‌نمایش خطا و تغییرات → تأیید → ثبت
```

کنترل‌ها

- فقط قالب‌های مجاز مانند `.xlsx`.
- محدودیت حجم و تعداد سطر.
- عدم اجرای فرمول یا ماکرو.
- تشخیص کد تکراری و ارتباط نامعتبر.
- حفظ صفر ابتدایی کدها و موبایل.
- قالب تاریخ صریح؛ عدم حدس‌زدن تاریخ مبهم.
- گزارش شماره سطر و علت خطا.
- انتخاب روشن بین افزودن و به‌روزرسانی.
- ثبت تاریخچه عملیات و بارگذار.
- عدم تولید رمز ساده مشترک برای همه کارکنان.

در خروجی Excel نیز مقادیر متنی مشکوک به فرمول باید ایمن‌سازی شوند. این نکته هر دو مسیر را پوشش می‌دهد: هم خواندن فایل کاربر نباید اجرای محتوا ایجاد کند و هم فایل خروجی سامانه نباید هنگام باز شدن در Excel رفتار غیرمنتظره داشته باشد.

پیشنهاد تکمیلی — سقف‌های پیش‌فرض بارگذاری: حداکثر حجم فایل ۱۰ مگابایت و حداکثر ۵۰٬۰۰۰ سطر در هر فایل پیشنهاد می‌شود. قالب تاریخ در هر ستون صریح اعلام شود (میلادی `YYYY-MM-DD` یا شمسی `YYYY/MM/DD` با انتخاب کاربر) و تاریخ‌های مبهم مانند `05/06` بدون تعیین قالب، خطا بگیرند نه حدس زده شوند. بارگذاری‌های بزرگ به‌صورت کار پس‌زمینه (Celery) با پیشرفت قابل مشاهده اجرا شوند.

سیاست داده و پایگاه داده

بخش‌های ۱۵ و ۱۶ ـ از سیاست حذف سه‌ماهه تا مدل داده

۱۵. سیاست حذف سه‌ماهه

تعریف پیشنهادی

در این سند، سه ماه تقویمی مبنای پیشنهادی است؛ نه ۹۰ روز ثابت. اگر ۹۰ روز ترجیح داده شود، تنظیم و آزمون‌ها باید مطابق آن تغییر کنند. انتخاب «سه ماه تقویمی» با تقویم شمسی سازمان سازگارتر است و مرزهای دوره‌ها را برای گزارش‌های مدیریتی قابل پیش‌بینی می‌کند.

جدول نگهداری

داده	سیاست
رویداد خام تردد	حذف پس از سه ماه با رعایت شرایط پاکسازی
مختصات و جزئیات موقعیت	همان دوره
پیام	حذف سه ماه پس از ارسال
فایل وابسته به پیام	در صورت وجود، همراه پیام
خلاصه قطعی کارکرد	حفظ؛ مدت نهایی نیازمند تصمیم
مشخصات شعب و پرسنل	تا زمان نیاز سازمان و سیاست مستقل
مرخصی و مأموریت	سیاست مستقل
گردش مانده مرخصی	حفظ برای صحت محاسبات
سوابق اصلاح و تأیید	سیاست مستقل و حداقل اطلاعات لازم
لاگ فنی و امنیتی	مدت مستقل، بدون کپی‌کردن متن پیام و مختصات

پیشنهاد تکمیلی — مقادیر پیشنهادی ستون‌های باز: خلاصه قطعی کارکرد: حداقل ۲ سال · مرخصی و مأموریت: حداقل ۲ سال · سوابق اصلاح و تأیید: حداقل ۲ سال (خلاصه‌شده، بدون محتوای پیام) · لاگ فنی و امنیتی: ۶ ماه · بکاپ: ۳۰ روز چرخشی. همه این مقادیر در تنظیمات محیط (`RETENTION_*`) قابل تنظیم و در گزارش پاکسازی قابل مشاهده باشند.

مبنای عمر تردد

عمر تردد بر اساس زمان مؤثر پذیرفته‌شده محاسبه شود، نه صرفاً زمان بارگذاری. بنابراین ارسال دیرهنگام رویداد قدیمی، عمر نگهداری آن را بی‌دلیل تمدید نکند. چنین رویدادی باید پیش از ورود به مسیر پاکسازی، رسیدگی شود.

شروط حذف امن

قبل از حذف تردد:

- بازه ورود و خروج مربوط قابل تفکیک و کامل باشد.
- خلاصه دوره مرتبط قطعی شده باشد.
- رویداد مشمول اختلاف حل‌نشده یا نگهداری مجاز نباشد.
- اصلاحات مرتبط در خلاصه اعمال شده باشند.
- وابستگی‌های دیتابیس و فایل‌ها شناسایی شده باشند.

رویدادهای دو طرف یک بازه، خصوصاً شیفت شب، نباید طوری حذف شوند که یک نیمه برای محاسبه باقی بماند. بنابراین واحد پاکسازی «بازه حضور» است، نه رویداد منفرد؛ بازه‌ای فقط وقتی حذف می‌شود که هر دو سر آن واجد شرایط باشند.

نکته عملیاتی مهم

اگر دوره تا موعد حذف بسته نشده باشد، سامانه باید هشدار بدهد. تعویق حذف نباید نامحدود و بی‌ثبت باشد.

سازمان باید بین این دو الزام سیاست صریح تعیین کند:

- حذف دقیق در موعد.
- نگهداری موقت برای رسیدگی قانونی یا اختلاف.

اثر حذف

پس از حذف داده خام:

- جزئیات دقیقه‌به‌دقیقه قابل بازسازی نیست.
- اصلاح کامل گذشته از روی رویدادها ممکن نیست.
- رسیدگی بر اساس خلاصه قطعی، مدارک باقی‌مانده و تعدیل مجاز انجام می‌شود.

آرشیو کردن، حذف محسوب نمی‌شود. اگر سازمان تصمیم بگیرد داده‌ها پیش از حذف آرشیو شوند، محل نگهداری آرشیو، مدت آن و کنترل دسترسی باید بخشی از همین سیاست تعریف شود.

نسخه پشتیبان

حذف از دیتابیس جاری به معنی حذف فوری از همه بکاپ‌ها نیست. باید تعیین شود:

- بکاپ‌ها چه مدت باقی می‌مانند.
- چه کسانی به آن‌ها دسترسی دارند.
- پس از بازیابی، پاکسازی دوباره اجرا شود.
- اطلاعات حذف‌شده ناخواسته دوباره در دسترس کاربران قرار نگیرد.

پیش از فعال‌سازی پاکسازی، الزامات قانونی و قراردادی نگهداری سوابق بررسی شوند.

۱۶. ساختار پیشنهادی پایگاه داده

جدول	کاربرد
`branches`	شعب
`regions`	مناطق
`employees`	پرونده پرسنل
`users`	حساب‌ها
`permissions`, `roles`	دسترسی
`employee_branch_assignments`	ارتباط تاریخ‌دار فرد و شعبه
`shifts`	تعریف شیفت
`shift_patterns`	الگوی چرخشی
`scheduled_shifts`	شیفت تخصیص‌یافته
`work_calendars`	تقویم و تعطیلات

جدول	کاربرد
`attendance_events`	رویدادهای خام
`attendance_sessions`	بازه‌های ورود و خروج
`attendance_adjustments`	اصلاح تردد
`leave_requests`	درخواست مرخصی
`leave_ledger`	گردش مانده
`mission_requests`	مأموریت
`approval_actions`	تصمیم‌ها
`conversations`, `messages`	پیام
`notifications`	اعلان
`monthly_summaries`	خلاصه کارکرد
`monthly_closures`	بستن دوره
`import_jobs`, `import_errors`	بارگذاری Excel
`audit_logs`	حسابرسی
`cleanup_runs`	نتیجه پاکسازی

محدودیت‌های ضروری

- کد شعبه و کد پرسنلی یکتا.
- شناسه رویداد آفلاین یکتا در دامنه تعریف‌شده.
- طول و عرض جغرافیایی هر دو موجود یا هر دو خالی باشند.
- زمان پایان بازه از شروع کمتر نباشد.
- خلاصه‌ها به رویداد خام، وابستگی حذف آبشاری نداشته باشند.
- عملیات مانده مرخصی و تصمیم‌ها تراکنشی و تکرارپذیر امن باشند.

محدودیت‌ها باید هم در سطح دیتابیس و هم در سطح برنامه اعمال شوند؛ اعتماد به اعتبارسنجی برنامه به‌تنهایی کافی نیست. برای جداول حساس مانند `attendance_events` و `leave_ledger`، حذف نرم توصیه نمی‌شود؛ چون سیاست نگهداری آن‌ها صریح است و حذف واقعی کنترل‌شده، ساده‌تر از مدیریت نسخه‌های پنهان است.

ایندکس‌ها

حداقل روی ترکیب‌های پرکاربرد:

- پرسنل و زمان تردد.
- شعبه و زمان تردد.
- وضعیت و تاریخ درخواست.
- گیرنده و زمان پیام.
- ماه، شعبه و پرسنل در خلاصه.
- زمان انقضای داده برای پاکسازی.

پارتیشن‌بندی ماهانه می‌تواند در ادامه بررسی شود؛ شرط اولیه موفقیت پروژه نیست. با مقیاس فعلی (حدود ۱۷ هزار رویداد در روز کاری)، ایندکس‌گذاری درست برای سال‌ها کافی است و تصمیم پارتیشن‌بندی باید بر اساس داده واقعی پس از پایلوت گرفته شود.

معماری فنی و Docker

بخش‌های ۱۷ تا ۲۵ ـ از فناوری تا روال استقرار

۱۷. فناوری پیشنهادی

بخش	پیشنهاد
Android	Flutter
PWA و پنل وب	React و TypeScript
بک‌اند	Django و Django REST Framework
ارتباط لحظه‌ای	Django Channels
دیتابیس	PostgreSQL و PostGIS
صف کار	Celery
واسط صف	Redis
وب‌سرور ورودی	Nginx
استقرار	Docker و Docker Compose

این انتخاب، مبنای فنی پیشنهادی سند است؛ نسخه دقیق وابستگی‌ها هنگام شروع پروژه انتخاب، تثبیت و آزمون شود. مجموعه انتخاب‌شده با یکدیگر سازگاری بلندمدت اثبات‌شده دارند و برای تیم‌های فارسی‌زبان، منابع یادگیری و استخدام نیز فراوان است.

معماری

```
Android / PWA / پنل مدیران
        |
      HTTPS
        |
      Nginx
        |
   API / WebSocket
        |
  Django مرکزی
   |         |
PostgreSQL   Redis
               |
            Worker
               |
   پاکسازی، Excel، گزارش، اعلان
```

برای این مقیاس، سامانه یکپارچه ماژولار نقطه شروع مناسبی است. تقسیم به میکروسرویس در این مرحله پیچیدگی عملیاتی بدون منفعت واقعی اضافه می‌کند؛ مرزهای ماژول درون Django باید تمیز نگه داشته شود تا در آینده در صورت نیاز، تفکیک سرویس‌ها ممکن باشد.

Docker محیط اجرا را یکسان می‌کند، اما به‌تنهایی دسترس‌پذیری بالا یا ظرفیت کافی تضمین نمی‌کند.

۱۸. سرویس‌های Docker

سرویس	مسئولیت
`gateway`	HTTPS، ارائه PWA، ارسال درخواست به API۱۹

سرویس	مسئولیت
`api`	API و WebSocket
`worker`	کارهای پس‌زمینه
`scheduler`	زمان‌بندی کارها
`migrate`	اجرای مهاجرت دیتابیس در استقرار
`db`	PostgreSQL/PostGIS
`redis`	صف و ارتباط لحظه‌ای

قواعد استقرار

- دیتابیس و Redis پورت عمومی نداشته باشند.
- فقط وب‌سرور ورودی در دسترس اینترنت باشد.
- داده دیتابیس روی Volume پایدار ذخیره شود.
- کانتینر اپلیکیشن با کاربر غیرریشه اجرا شود.
- محیط توسعه، آزمون و تولید جدا باشند.
- فقط یک نمونه Scheduler فعال باشد.
- Migration از یک مسیر کنترل‌شده اجرا شود.
- تنظیمات و رمزها داخل Git یا Image قرار نگیرند.
- نسخه Imageها مشخص و در تولید ترجیحاً با Digest تثبیت شود.
- لاگ‌ها چرخش و محدودیت حجم داشته باشند.

این قواعد بخشی از معیارهای پذیرش استقرار هستند و در آزمون پذیرش (بخش ۳۱) کنترل می‌شوند؛ به‌ویژه بسته‌بودن پورت‌های دیتابیس و اجرای غیرریشه که در ممیزی‌های امنیتی رایج‌ترین یافته‌های منفی هستند.

۱۹. ساختار پیشنهادی مخزن

```
rose-attendance/
├── backend/
│   ├── Dockerfile
│   ├── requirements.lock
│   ├── manage.py
│   ├── config/
│   └── apps/
│       ├── accounts/
│       ├── branches/
│       ├── employees/
│       ├── shifts/
│       ├── attendance/
│       ├── leave/
│       ├── missions/
│       ├── messaging/
│       ├── reports/
│       ├── imports/
│       └── retention/
├── frontend/
│   ├── Dockerfile
│   ├── package.json
│   ├── package-lock.json
│   └── src/
├── mobile/
├── deploy/
│   └── nginx.conf
```

```
├── secrets/
├── compose.yml
├── .env.example
├── .gitignore
└── docs/
```

پوشه `secrets/` و فایل‌های محیط واقعی نباید وارد مخزن شوند. این مخزن با همین ساختار آغاز شده است؛ فایل‌های استقرار (Dockerfile، Compose، Nginx و `.env.example`) مطابق سند ایجاد شده‌اند و کد اپلیکیشن در فاز توسعه تکمیل می‌شود.

۲۰. نمونه Dockerfile بک‌اند

نمونه زیر قالب استقرار است، نه کد کامل سامانه. وجود پروژه Django، فایل قفل وابستگی‌ها و تنظیمات مربوط ضروری است.

```
FROM python:3.12-slim

ENV PYTHONDONTWRITEBYTECODE=1 \
    PYTHONUNBUFFERED=1 \
    PIP_NO_CACHE_DIR=1

WORKDIR /app

RUN apt-get update \
    && apt-get install -y --no-install-recommends \
       libpq5 libgdal32 libgeos-c1v5 \
    && rm -rf /var/lib/apt/lists/*

COPY requirements.lock /app/requirements.lock

RUN pip install --require-hashes -r requirements.lock

RUN groupadd --gid 10001 app \
    && useradd --uid 10001 --gid app \
       --create-home app

COPY --chown=app:app . /app

USER app

EXPOSE 8000

CMD ["gunicorn", "config.asgi:application", \
     "-k", "uvicorn_worker.UvicornWorker", \
     "--bind", "0.0.0.0:8000", \
     "--workers", "2", \
     "--access-logfile", "-", \
     "--error-logfile", "-"]
```

ملاحظات

- نام بسته‌های سیستمی باید با توزیع پایه انتخاب‌شده تطبیق داده شود.
- `requirements.lock` باید شامل نسخه‌ها و هش‌های معتبر باشد.
- `gunicorn` و `uvicorn-worker` باید در وابستگی‌ها وجود داشته باشند.
- تعداد Worker بر اساس آزمون بار تعیین شود.
- در تولید، Image پایه به نسخه یا Digest مشخص تثبیت شود.

۲۱. نمونه Dockerfile وب و PWA

```
FROM node:22-alpine AS build
```

```
WORKDIR /app

COPY package.json package-lock.json ./
RUN npm ci

COPY . .
RUN npm run build

FROM nginx:stable-alpine

COPY --from=build /app/dist /usr/share/nginx/html
COPY nginx.conf /etc/nginx/conf.d/default.conf

EXPOSE 80 443
```

در این ساختار، فایل تنظیم Nginx باید هنگام Build در Context فرانت‌اند موجود باشد یا مسیر کپی متناسب تغییر کند. فایل‌های دارای اطلاعات حساس نباید وارد Context ساخت شوند؛ استفاده از `.dockerignore` ضروری است.

۲۲. نمونه Docker Compose

این نمونه برای استقرار تک‌میزبانی کنترل‌شده است و باید پس از پیاده‌سازی پروژه تکمیل و آزمون شود.

```
name: rose-attendance

x-app: &app
  image: rose-attendance-backend:${APP_VERSION:?APP_VERSION is required}
  build:
    context: ./backend
  env_file:
    - .env
  secrets:
    - django_secret
    - db_password
  environment:
    DJANGO_SETTINGS_MODULE: config.settings.production
    DJANGO_SECRET_KEY_FILE: /run/secrets/django_secret
    DB_PASSWORD_FILE: /run/secrets/db_password
    DB_HOST: db
    DB_PORT: "5432"
    REDIS_URL: redis://redis:6379/0
  networks:
    - backend
  init: true
  security_opt:
    - no-new-privileges:true
  logging:
    driver: json-file
    options:
      max-size: "10m"
      max-file: "5"

services:
  db:
    image: postgis/postgis:16-3.4
    restart: unless-stopped
    environment:
      POSTGRES_DB: rose_attendance
      POSTGRES_USER: rose_app
      POSTGRES_PASSWORD_FILE: /run/secrets/db_password
    secrets:
      - db_password
    volumes:
      - pgdata:/var/lib/postgresql/data
    networks:
      - backend
```

```
  healthcheck:
    test:
      - CMD-SHELL
      - pg_isready -U rose_app -d rose_attendance
    interval: 10s
    timeout: 5s
    retries: 10

redis:
  image: redis:7.4-alpine
  restart: unless-stopped
  command:
    - redis-server
    - --appendonly
    - "yes"
    - --maxmemory-policy
    - noeviction
  volumes:
    - redisdata:/data
  networks:
    - backend
  healthcheck:
    test: ["CMD", "redis-cli", "ping"]
    interval: 10s
    timeout: 3s
    retries: 10

migrate:
  <<: *app
  restart: "no"
  command: ["python", "manage.py", "migrate", "--noinput"]
  depends_on:
    db:
      condition: service_healthy

api:
  <<: *app
  restart: unless-stopped
  depends_on:
    migrate:
      condition: service_completed_successfully
    redis:
      condition: service_healthy
  healthcheck:
    test:
      - CMD
      - python
      - -c
      - >
        import urllib.request;
        urllib.request.urlopen(
        'http://127.0.0.1:8000/health/ready', timeout=3)
    interval: 15s
    timeout: 5s
    retries: 5

worker:
  <<: *app
  restart: unless-stopped
  command:
    - celery
    - -A
    - config
    - worker
    - --loglevel=INFO
    - --concurrency=2
  depends_on:
    migrate:
      condition: service_completed_successfully
```

```
      redis:
        condition: service_healthy

  scheduler:
    <<: *app
    restart: unless-stopped
    command:
      - celery
      - -A
      - config
      - beat
      - --loglevel=INFO
      - --schedule=/var/lib/celery/celerybeat-schedule
    volumes:
      - beatdata:/var/lib/celery
    depends_on:
      migrate:
        condition: service_completed_successfully
      redis:
        condition: service_healthy

  gateway:
    image: rose-attendance-web:${APP_VERSION:?APP_VERSION is required}
    build:
      context: ./frontend
    restart: unless-stopped
    ports:
      - "80:80"
      - "443:443"
    volumes:
      - ./deploy/tls:/etc/nginx/tls:ro
    depends_on:
      api:
        condition: service_healthy
    networks:
      - backend

volumes:
  pgdata:
  redisdata:
  beatdata:

networks:
  backend:

secrets:
  django_secret:
    file: ./secrets/django_secret.txt
  db_password:
    file: ./secrets/db_password.txt
```

الزامات تکمیل این نمونه

- تنظیمات Django باید متغیرهای `*_FILE` را واقعاً از فایل بخوانند؛ این قابلیت خودکار نیست.
- مجوز Volume زمان‌بند باید برای کاربر غیرریشه آماده شود.
- مسیر `/health/ready` باید پیاده‌سازی شود.
- تنظیمات `ALLOWED_HOSTS` و HTTPS باید با دامنه واقعی سازگار باشند.
- اتصال Redis در این نمونه فقط داخلی است؛ امنیت شبکه میزبان و محدودیت دسترسی ضروری است.
- برای تولید حساس، حساب Migration از حساب اجرای عادی جدا شود.
- فایل Secret در Docker Compose جایگزین سامانه کامل مدیریت رمز نیست؛ مجوز فایل و مدیریت امن میزبان لازم است.
- صف نباید با سیاست حذف خودکار کلیدهای حافظه از بین برود.
- پایش مصرف RAM و دیسک Redis ضروری است.

۲۳. تنظیم Nginx

قالب زیر به دامنه و گواهی واقعی نیاز دارد:

```
map $http_upgrade $connection_upgrade {
    default upgrade;
    ''      close;
}

server {
    listen 80;
    server_name attendance.example.com;

    return 301 https://$host$request_uri;
}

server {
    listen 443 ssl;
    server_name attendance.example.com;

    ssl_certificate     /etc/nginx/tls/fullchain.pem;
    ssl_certificate_key /etc/nginx/tls/privkey.pem;
    ssl_protocols TLSv1.2 TLSv1.3;

    root /usr/share/nginx/html;
    index index.html;

    client_max_body_size 20m;

    location /api/ {
        proxy_pass http://api:8000;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
        proxy_set_header X-Forwarded-Proto $scheme;
    }

    location /ws/ {
        proxy_pass http://api:8000;
        proxy_http_version 1.1;
        proxy_set_header Upgrade $http_upgrade;
        proxy_set_header Connection $connection_upgrade;
        proxy_set_header Host $host;
        proxy_set_header X-Forwarded-Proto $scheme;
        proxy_read_timeout 75s;
    }

    location = /sw.js {
        add_header Cache-Control "no-cache";
        try_files $uri =404;
    }

    location / {
        try_files $uri $uri/ /index.html;
    }
}
```

نکات

- گواهی باید معتبر و تمدید آن خودکار باشد.
- اعتماد به هدرهای Proxy فقط برای ورودی کنترل‌شده تنظیم شود.
- احراز هویت WebSocket و کنترل Origin در برنامه انجام شود.
- مسیر سلامت داخلی نباید حاوی اطلاعات حساس باشد.

- فایل‌های پیوست خصوصی از مسیر عمومی Nginx ارائه نشوند.
- حد حجم Excel در برنامه و وب‌سرور هماهنگ باشد.

۲۴. تنظیمات محیط

نمونه `.env.example`:

```
APP_VERSION=1.0.0

DJANGO_DEBUG=False
DJANGO_ALLOWED_HOSTS=attendance.example.com,127.0.0.1
DJANGO_CSRF_TRUSTED_ORIGINS=https://attendance.example.com

DB_NAME=rose_attendance
DB_USER=rose_app

BUSINESS_TIME_ZONE=Asia/Tehran

RETENTION_MONTHS=3
OFFLINE_NORMAL_WINDOW_DAYS=7
```

نام متغیرها قرارداد پروژه است؛ برنامه باید آن‌ها را بخواند و اعتبارسنجی کند. فعال شدن حذف خودکار بهتر است با تنظیم جداگانه و پس از تأیید سیاست انجام شود، نه صرفاً با مقدار پیش‌فرض.

پیشنهاد تکمیلی — متغیرهای اضافه پیشنهادی: `CLEANUP_ENABLED=False` (کلید جداگانه فعال‌سازی پاکسازی)، `RETENTION_SUMMARY_MONTHS=24`، `CLOCK_SKEW_MINUTES=5`، `SYNC_MAX_BATCH=100`، `SESSION_REFRESH_DAYS=7`، `SESSION_ACCESS_MINUTES=15` و `UPLOAD_MAX_MB=10`. همه مقادیر باید در استارتاپ برنامه اعتبارسنجی شوند و مقدار نامعتبر، جلوی بالا آمدن سرویس را بگیرد.

۲۵. روال استقرار

استقرار اولیه

```
docker compose config
docker compose build
docker compose up -d db redis
docker compose run --rm migrate
docker compose up -d api worker scheduler gateway
docker compose ps
```

مشاهده وضعیت

```
docker compose logs --tail=100 api
docker compose logs --tail=100 worker
docker compose logs --tail=100 gateway
```

به‌روزرسانی نسخه

1. آزمون نسخه در محیط Stage.
2. تهیه بکاپ معتبر.
3. بررسی سازگاری Migration.
4. تغییر نسخه Image.
5. اجرای Migration کنترل‌شده.
6. راه‌اندازی نسخه جدید.

7. آزمون ثبت تردد، همگام‌سازی و پیام.

8. پایش خطاها.

بازگشت Image همیشه به معنی امکان بازگشت دیتابیس نیست. Migrationها باید با برنامه Rollback و ترجیحاً الگوی تغییرات سازگار (expand–contract) طراحی شوند.

اجرای این دستور روی تولید ممکن است داده Volumeها را حذف کند و نباید در راهنمای عادی عملیات باشد:

```
docker compose down -v
```

بخش چهارم

API، امنیت و عملیات

بخش‌های ۲۶ تا ۳۰ ـ از قرارداد API تا پاکسازی خودکار

۲۶. APIهای اصلی

مسیر پیشنهادی	کاربرد
`POST /api/v1/auth/login`	ورود
`POST /api/v1/auth/refresh`	تمدید نشست در صورت استفاده از توکن
`GET /api/v1/me`	اطلاعات کاربر
`GET /api/v1/me/branches`	شعب مجاز
`GET /api/v1/me/schedule`	برنامه کاری
`POST /api/v1/attendance/events`	ثبت تردد
`POST /api/v1/attendance/sync`	ارسال دسته‌ای آفلاین
`GET /api/v1/attendance/events`	مشاهده تردد مجاز
`POST /api/v1/attendance/adjustments`	اصلاح
`POST /api/v1/leave-requests`	مرخصی
`POST /api/v1/mission-requests`	مأموریت
`POST /api/v1/requests/{id}/decision`	تصمیم مدیر
`GET /api/v1/monthly-summaries`	کارکرد
`POST /api/v1/imports`	بارگذاری Excel
`GET /api/v1/imports/{id}`	نتیجه بارگذاری
`POST /api/v1/messages`	پیام

نمونه ثبت بدون موقعیت

```
{
  "event_id": "83ae7867-e7a7-4a2b-badc-e0c48b627f9a",
  "branch_id": 125,
  "event_type": "CHECK_IN",
  "client_time": "2026-10-23T08:00:00+03:30",
  "offline": false,
```

```
  "location": null,
  "location_reason": "PERMISSION_DENIED"
}
```

پاسخ پیشنهادی

```
{
  "event_id": "83ae7867-e7a7-4a2b-badc-e0c48b627f9a",
  "status": "ACCEPTED",
  "location_status": "UNAVAILABLE",
  "manager_approval_required": false
}
```

هویت پرسنل باید از نشست معتبر استخراج شود، نه از شناسه‌ای که کاربر در بدنه درخواست می‌فرستد.

پیشنهاد تکمیلی — قراردادهای مشترک API: همه درخواست‌های احرازشده با هدر `Authorization: Bearer <token>` ارسال شوند. پاسخ خطا با پوشش یکنواخت `{"code": "...", "message": "..."}` و کدهای پایدار (مثل `DUPLICATE_EVENT`، `BRANCH_NOT_ALLOWED`) برگردد. صفحه‌بندی با `limit/offset` و سقف `limit=100` باشد. ارسال مجدد رویداد با همان `event_id` همیشه همان نتیجه قبلی را برگرداند (رفتار تکرارپذیر). سقف نرخ ثبت برای هر کاربر پیشنهاداً ۶۰ درخواست در دقیقه تنظیم شود و پاسخ `429` همراه هدر `Retry-After` داده شود.

۲۷. امنیت

- HTTPS برای تمام ارتباطات.
- محدودیت تلاش ورود و نرخ درخواست.
- کنترل مجوز در سطح رکورد.
- حفاظت از رمز، توکن و کلیدها.
- عدم ثبت متن پیام، رمز یا مختصات کامل در لاگ عمومی.
- احراز هویت چندمرحله‌ای مدیران حساس.
- محافظت CSRF برای نشست‌های Cookieمحور.
- سیاست مشخص نگهداری توکن در PWA.
- محدودیت فایل و بررسی محتوا.
- به‌روزرسانی وابستگی‌ها و اسکن Imageها.
- رمزنگاری دیسک و بکاپ در صورت پشتیبانی زیرساخت.
- ثبت تغییر تنظیمات، دسترسی و خلاصه کارکرد.

جمع‌آوری شناسه دستگاه نیز باید حداقلی و متناسب با هدف باشد؛ به آن به‌عنوان اثبات قطعی هویت اعتماد نشود.

پیشنهاد تکمیلی — سخت‌سازی پیش‌فرض‌ها: در لایه Nginx هدرهای `X-Content-Type-Options: nosniff`، `Strict-Transport-Security` و `Content-Security-Policy` محدود برای PWA تنظیم شود. توکن PWA در `httpOnly` و Cookie `Secure` نگهداری شود تا در برابر اسکریپت‌های مخرب مقاوم‌تر باشد. اسکن خودکار وابستگی‌ها و Imageها به‌صورت هفتگی در مسیر CI اجرا شود. بازبینی دسترسی‌ها هر سه ماه یک‌بار توسط منابع انسانی و مدیر سامانه انجام و نتیجه آن ثبت گردد.

۲۸. پشتیبان‌گیری و بازیابی

داده‌های قابل پشتیبان‌گیری

- PostgreSQL.
- فایل‌های خصوصی مجاز.

- تنظیمات ضروری استقرار.
- اطلاعات لازم بازیابی، با حفاظت مناسب کلیدها.

Redis منبع اصلی حقیقت تردد نباشد؛ پذیرش تردد پس از ثبت پایدار در دیتابیس اعلام شود.

اهداف پیشنهادی

- **RPO:** حداکثر ۱۵ دقیقه اتلاف داده در سناریوی توافق‌شده.
- **RTO:** حداکثر ۴ ساعت برای بازیابی خدمت.

این اهداف بدون زیرساخت و آزمون، تعهد قطعی محسوب نمی‌شوند. برای RPO کوتاه، بکاپ روزانه به‌تنهایی کافی نیست و سازوکاری مانند آرشیو WAL و بازیابی نقطه‌ای لازم است.

الزامات

- بکاپ خارج از میزبان اصلی.
- کنترل دسترسی و رمزنگاری.
- گزارش موفقیت و شکست.
- آزمایش دوره‌ای بازیابی.
- اجرای مجدد سیاست حذف پس از Restore.
- تعیین مدت نگهداری بکاپ متناسب با سیاست حریم خصوصی.

> **پیشنهاد تکمیلی — طرح عملیاتی پیشنهادی برای RPO ۱۵ دقیقه:** بکاپ کامل روزانه با `pgBackRest` به مقصد خارج از میزبان، آرشیو WAL هر ۵ دقیقه و یک آزمون بازیابی کامل در هر ماه با ثبت گزارش. کلیدهای رمزنگاری بکاپ جدا از خود بکاپ نگهداری شوند و دسترسی به مقصد بکاپ فقط از مسیر حساب سرویس محدود شود.

۲۹. پایش و ظرفیت

شاخص‌های لازم

- زمان پاسخ API.
- نرخ خطا.
- تعداد تردد پذیرفته‌شده.
- تأخیر همگام‌سازی.
- طول صف و شکست کارها.
- اتصال و زمان پاسخ دیتابیس.
- مصرف CPU، RAM و دیسک.
- وضعیت بکاپ.
- نتیجه پاکسازی.
- تاریخ انقضای گواهی HTTPS.

برآورد حجم اولیه

با فرض دو تردد روزانه:

```
۸٬۵۰۰ رویداد در روز کاری حدود ۱۷٬۰۰۰ = ۲ × نفر
```

ترددهای اضافی، پیام و اصلاحات به این مقدار اضافه می‌شوند.

اهداف پیشنهادی آزمون

- سناریوی اوج ورود و خروج.
- همگام‌سازی دسته‌ای پس از قطعی منطقه‌ای.
- ثبت هم‌زمان از Android و PWA.
- گزارش‌گیری هنگام ثبت تردد.
- ارسال دوباره ناشی از اینترنت ضعیف.
- خرابی Worker بدون از دست‌رفتن داده اصلی.

هدف اولیه پاسخ API می‌تواند کمتر از سه ثانیه برای ۹۵٪ درخواست‌ها در بار توافق‌شده باشد؛ زمان دریافت موقعیت و کیفیت اینترنت کاربر جدا اندازه‌گیری شوند.

یک میزبان Docker، نقطه شکست واحد دارد. اگر دسترس‌پذیری بالا الزام قراردادی شود، افزونگی میزبان، دیتابیس و مسیر ورودی باید جدا طراحی و هزینه‌گذاری شود.

پیشنهاد تکمیلی — آستانه‌های هشدار پیش‌فرض: نرخ خطای API بالاتر از ۲٪ در ۵ دقیقه، طول صف Celery بیش از ۱٬۰۰۰ کار، تأخیر همگام‌سازی p95 بیش از ۵ دقیقه، فضای آزاد دیسک کمتر از ۲۰٪ و نزدیکی انقضای گواهی به کمتر از ۱۴ روز؛ هرکدام هشدار با شدت مشخص به کانال مسئول فنی ارسال شود. حداقل پیاده‌سازی: خروجی Prometheus از Django و Celery و داشبورد ساده؛ ابزارهای پیچیده‌تر شرط شروع پروژه نیستند.

۳۰. کار پاکسازی خودکار

پاکسازی روزانه در Worker انجام شود و Scheduler فقط آن را زمان‌بندی کند.

الگوریتم

```
۱. دریافت قفل اجرای یکتا
۲. تعیین مرز سه‌ماهه
۳. شناسایی داده واجد حذف
۴. بررسی بسته‌شدن دوره و وابستگی‌ها
۵. حذف دسته‌ای و کنترل‌شده
۶. حذف فایل‌های وابسته
۷. ثبت تعداد حذف و موارد متوقفشده
۸. ارسال هشدار در صورت خطا
۹. آزادکردن قفل
```

الزامات

- اجرای هم‌زمان چند پاکسازی جلوگیری شود.
- حذف دسته‌ای باشد تا دیتابیس طولانی قفل نشود.
- حالت dry-run داشته باشد.
- شکست جزئی قابل بازیابی باشد.
- خلاصه‌های ماهانه حذف نشوند.
- پیام‌های پاک‌شده در اعلان یا فایل جانبی باقی نمانند.
- گزارش پاکسازی شامل خود محتوای حذف‌شده نباشد.
- دسترسی اجرای دستی محدود باشد.

کوئری ساده‌ای که همه ترددهای قدیمی را فقط بر اساس تاریخ حذف کند، برای این سامانه کافی و امن نیست. نتیجه هر اجرا در جدول `cleanup_runs` ثبت می‌شود تا حسابرسی بتواند در هر لحظه بگوید چه داده‌ای، در چه تاریخی و با کدام شرایط حذف شده است.

آزمون، اجرا و تحویل

بخش‌های ۳۱ تا ۳۴ ـ از معیارهای پذیرش تا موارد تصویب‌شده

۳۱. معیارهای پذیرش نسخه اول

اطلاعات پایه

- بارگذاری Excel با پیش‌نمایش و گزارش خطا.
- جلوگیری از کد تکراری.
- مدیریت ارتباط چندشعبه‌ای تاریخ‌دار.

تردد

- ثبت با موقعیت.
- ثبت بدون موقعیت بدون تأیید مدیر.
- ثبت آفلاین بدون موقعیت.
- ارسال مجدد بدون تکرار.
- مدیریت شیفت شب.
- کنترل تداخل شعب و تردد ناقص.

محاسبات

- تطابق با نمونه‌های دستی منابع انسانی.
- عدم دوباره‌شماری حضور، مرخصی و مأموریت.
- محاسبه برنامه ثابت و چرخشی.
- حفظ نسخه خلاصه قطعی.

درخواست و پیام

- ارجاع به مدیر شعبه صحیح.
- عدم تأیید درخواست شخص توسط خودش.
- کنترل تکرار تصمیم.
- محدودیت گیرندگان پیام.
- حذف پیام مطابق سیاست.

زیرساخت

- Build و استقرار Docker.
- عدم انتشار عمومی PostgreSQL و Redis.
- حفظ داده با بازسازی کانتینر.
- آزمون بار و امنیت.
- بازیابی موفق بکاپ.
- آزمون واقعی پاکسازی و حفظ خلاصه‌ها.
- آزمون PWA روی مرورگرهای هدف.

هر یک از این معیارها باید به سناریوی آزمون قابل اجرا تبدیل شود و نتیجه اجرای آن‌ها در «گزارش آزمون‌ها» (از اقلام تحویل) مستند گردد. معیار پذیرش بدون سناریو و نتیجه ثبت‌شده، در تحویل نهایی ملاک محسوب نمی‌شود.

۳۲. فازهای اجرا

فاز ۱: تحلیل نهایی

- دریافت نمونه Excel.
- دریافت قوانین کارکرد.
- تعیین مدیران و جانشین‌ها.
- تصویب سیاست حذف و نگهداری.
- تعیین مرورگرها و نسخه‌های Android هدف.

فاز ۲: طراحی

- مدل داده.
- API.
- صفحات و تجربه کاربری.
- مدل آفلاین.
- امنیت و ساختار Docker.

فاز ۳: توسعه هسته

- شعب و پرسنل.
- Excel.
- حساب‌ها.
- شیفت.
- تردد آنلاین و آفلاین.
- محاسبات اولیه.

فاز ۴: تکمیل نسخه اول

- مرخصی و مأموریت.
- پیام.
- گزارش و بستن ماه.
- پاکسازی.
- پایش و پشتیبان‌گیری.

فاز ۵: پایلوت

اجرا در حدود ۵ تا ۱۰ شعبه با شرایط متفاوت:

- اینترنت ضعیف.
- موقعیت‌یابی نامناسب.
- شیفت شب.
- کارکنان چندشعبه‌ای.
- دستگاه‌ها و مرورگرهای مختلف.

فاز ۶: استقرار سراسری

- رفع مشکلات پایلوت.
- آموزش.
- ورود مرحله‌ای داده.

- گسترش منطقه‌به‌منطقه.
- پشتیبانی و پایش.

زمان و هزینه نهایی باید پس از بررسی نمونه داده‌ها، قواعد محاسبه و طراحی صفحات برآورد شود.

پیشنهاد تکمیلی — برآورد اولیه مدت فازها (صرفاً برای برنامه‌ریزی، قطعی نیست): فاز ۱: ۲ تا ۳ هفته · فاز ۲: ۳ تا ۴ هفته · فاز ۳: ۸ تا ۱۰ هفته · فاز ۴: ۶ تا ۸ هفته · فاز ۵: ۴ تا ۶ هفته · فاز ۶: ۴ تا ۸ هفته به‌ازای هر موج منطقه‌ای. جمع حداقلی حدود ۶ تا ۸ ماه تا پایان پایلوت است؛ این اعداد بدون نمونه داده و تأیید قواعد محاسبه، مبنای تعهد قراردادی قرار نمی‌گیرند.

۳۳. اقلام تحویل

تیم توسعه باید تحویل دهد:

- کد منبع Android، PWA و بک‌اند.
- فایل‌های Docker و Compose.
- فایل قفل وابستگی‌ها.
- مستند نصب و به‌روزرسانی.
- مستند API.
- طراحی دیتابیس و Migrationها.
- قالب‌های Excel.
- راهنمای کاربران و مدیران.
- گزارش آزمون‌ها.
- دستورالعمل بکاپ و Restore.
- دستورالعمل پاکسازی.
- راهنمای رسیدگی به تردد ناقص و تعارض آفلاین.
- برنامه پشتیبانی.
- فهرست وابستگی‌های بیرونی و هزینه‌های آن‌ها.

مالکیت کد، داده، دامنه، حساب مرکز داده، گواهی‌ها و حساب‌های انتشار Android باید در قرارداد روشن شود.

۳۴. موارد تصویب‌شده (نسخه ۲٫۱)

موارد این جدول در بازبینی نسخه ۲٫۱ با تأیید کارفرما به‌صورت قطعی تصویب شده‌اند و از این پس مبنای طراحی، توسعه، قرارداد و معیارهای پذیرش قرار می‌گیرند. هر تغییر آتی در هر یک از این تصمیم‌ها باید در قالب نسخه جدید این سند ثبت شود. هیچ‌یک از این موارد نباید ضمن توسعه و بر اساس سلیقه پیاده‌سازی تصمیم‌گیری شود؛ زیرا هرکدام مستقیماً بر داده، گزارش یا تعهد عملیاتی اثر می‌گذارند.

موضوع	تصمیم مصوب	ارجاع در سند
خلاصه ماهانه	پس از حذف جزئیات سه‌ماهه، خلاصه قطعی کارکرد ماهانه حفظ و حداقل ۲ سال نگهداری می‌شود؛ پاکسازی جزئیات هر دوره منوط به موجود بودن خلاصه قطعی همان دوره است.	بخش ۱۳ و ۱۵
تعریف سه ماه	مبنای دوره‌های سه‌ماهه و بازه‌های نگهداری، تقویم شمسی سازمان است و هر دوره منطبق بر فصل‌های تقویم شمسی تعریف می‌شود.	بخش ۱۵
موقعیت خارج محدوده	ثبت رویداد با برچسب «خارج محدوده»، بدون رد خودکار و بدون الزام تأیید مدیر؛ شعاع پیش‌فرض ۱۵۰ متر برای شعب شهری و ۳۰۰ متر برای کلینیک‌ها و سایت‌های بزرگ، قابل تنظیم برای هر شعبه در بازه ۵۰ تا ۱٬۰۰۰ متر.	بخش ۴ و ۷

موضوع	تصمیم مصوب	ارجاع در سند
مدت معمول آفلاین	همگام‌سازی خودکار ثبت‌های آفلاین تا ۷ روز؛ فراتر از آن ثبت انجام اما رویداد وارد وضعیت `NEEDS_REVIEW` شده و زمان مؤثر فقط با تصمیم مدیر یا منابع انسانی تثبیت می‌شود. اختلاف ساعت دستگاه با سرور بیش از ±۵ دقیقه با پرچم `CLOCK_SKEW` علامت‌گذاری می‌شود.	بخش ۹
مرخصی و مأموریت چندشعبه‌ای	تصمیم‌گیری مستقل برای هر بخش (شعبه و شیفت) و نمایش وضعیت کلی ترکیبی در پروفایل پرسنل.	بخش ۱۱
نگهداری خلاصه و درخواست‌ها	سیاست نگهداری مستقل از جزئیات؛ حداقل ۲ سال برای خلاصه‌های قطعی کارکرد و سوابق درخواست‌های مرخصی و مأموریت.	بخش ۱۵
قوانین تأخیر و اضافه‌کاری	دریافت از منابع انسانی و تعریف به‌صورت داده با نسخه‌بندی و تاریخ اعتبار؛ بدون کد ثابت.	بخش ۱۰
روش انتشار Android	ابتدا توزیع داخلی APK امضاشده از طریق MDM یا کانال داخلی شرکت؛ انتشار در بازارهای داخلی صرفاً با تصمیم کارفرما در فازهای بعدی.	بخش ۳۲
مرورگرهای پشتیبانی PWA	Chrome و Edge در دو نسخه پایدار آخر به‌علاوه Android WebView (بر پایه Chromium)؛ سایر مرورگرها بدون تضمین سازگاری و فقط پس از آزمون پذیرفته می‌شوند.	بخش ۳۲
هدف دسترس‌پذیری	هدف اولیه ۹۹٪ در ماه با تک‌میزبان و بکاپ منظم؛ ارتقا به افزونگی فعال فقط در صورت الزام قراردادی یا رشد عملیاتی و با هزینه‌گذاری مستقل.	بخش ۲۹

این تصویب به‌صورت ثبت رسمی در تاریخچه نسخه‌های همین سند (نسخه ۲٫۱) صورت گرفته است و کامیت مربوطه در مخزن پروژه سند این تصمیم است؛ در نتیجه جلسه جداگانه تکمیلی برای این ده مورد ضروری نیست. سند نسخه ۲٫۱ از این پس «مرجع واحد پروژه» است و هیچ تصمیم عطف‌به‌ماضایی خارج از آن اعتبار ندارد.

جمع‌بندی اجرایی

سامانه رز سفید بر پایه API، PWA، Android مرکزی و استقرار Docker طراحی می‌شود. سه اصل قطعی آن عبارت‌اند از:

1. **ثبت تردد بدون GPS مجاز است و تأیید مدیر نمی‌خواهد.**
2. **ثبت آفلاین از نسخه اول وجود دارد و پس از اتصال بدون تکرار همگام می‌شود.**
3. **جزئیات تردد، موقعیت و پیام سه‌ماهه هستند و حفظ خلاصه کارکرد ماهانه (حداقل ۲ سال) در نسخه ۲٫۱ به‌صورت رسمی تصویب شده است.**

نمونه‌های Docker این سند، قالب معماری و استقرار هستند؛ نرم‌افزار کامل و آماده اجرا محسوب نمی‌شوند. این سند مبنای مناسبی برای تهیه قرارداد توسعه، طراحی دیتابیس، طراحی صفحات و تقسیم کار تیم فنی است.

واژه‌نامه

اصطلاح	معنا در این سند
رویداد تردد	یک ثبت ورود یا خروج، همراه با متادیتای کامل بند ۷٫۲
بازه حضور	جفت رویداد ورود و خروج که محاسبه کارکرد بر اساس آن انجام می‌شود
زمان مؤثر	زمان پذیرفته‌شده سرور برای محاسبه؛ ممکن است پس از رسیدگی با زمان دستگاه یکسان نباشد
ثبت آفلاین	ذخیره رویداد روی دستگاه هنگام قطع ارتباط و ارسال آن پس از اتصال با همان شناسه
تردد ناقص	ورود بدون خروج، خروج بدون ورود یا ترتیب نامعتبر رویدادها
خلاصه قطعی	نسخه نهایی‌شده کارکرد ماهانه پس از بستن دوره که مبنای رسیدگی‌های بعدی است
پاکسازی	حذف کنترل‌شده داده جزئی مطابق بخش ۱۵ با شروط امن و ثبت در `cleanup_runs`
جانشین	فردی که در غیاب مدیر شعبه، اختیار تأیید را با هویت خود اعمال می‌کند

اصطلاح	معنا در این سند
برچسب موقعیت	وضعیت روشن موقعیت رویداد: در محدوده، خارج محدوده، ناموجود، کم‌دقت

پیوست ـ نگاشت فایل‌های مخزن به بخش‌های سند

برای سهولت بازبینی و توسعه، نگاشت فایل‌های استقرار موجود در مخزن به بخش‌های مرجع این سند به شرح زیر است:

فایل در مخزن	بخش مرجع سند
`docs/REQUIREMENTS.md`	کل سند (نسخه قابل مرور در GitHub)
`docs/REQUIREMENTS.pdf`	نسخه رسمی قابل چاپ و امضای همین سند
`compose.yml`	بخش ۲۲ ـ نمونه Docker Compose و الزامات تکمیل آن
`backend/Dockerfile`	بخش ۲۰ ـ نمونه Dockerfile بک‌اند و ملاحظات
`frontend/Dockerfile` و `frontend/nginx.conf`	بخش ۲۱ و ۲۳ ـ ساخت Image وب و پیکربندی Nginx
`deploy/nginx.conf`	بخش ۲۳ ـ نسخه مرجع عملیاتی پیکربندی Nginx
`.env.example`	بخش ۲۴ ـ تنظیمات محیط و متغیرهای پیشنهادی
`.gitignore`	بخش ۱۹ ـ بلااقتصاد ماندن `secrets/` و فایل‌های محیط

هر تغییری در این فایل‌ها باید با بخش مرجع خود تطبیق داده شود؛ در صورت مغایرت، به‌روزرسانی سند یا فایل بر اساس تصمیم کارفرما ثبت و مستند می‌شود تا نسخه مرجع واحد همیشه معتبر بماند.

سامانه حضور و غیاب رز سفید

سه اصل قطعی پروژه — مبنای طراحی، توسعه، آزمون و برآورد

۱ **ثبت تردد بدون GPS مجاز است و تأیید مدیر نمی‌خواهد.**

۲ **ثبت آفلاین از نسخه اول وجود دارد و پس از اتصال بدون تکرار همگام می‌شود.**

۳ **جزئیات تردد، موقعیت و پیام سه‌ماهه هستند؛ حفظ خلاصه کارکرد فرض شده و باید تأیید نهایی شود.**

سند جامع نیازمندی‌ها، معماری و استقرار · نسخه ۲٫۰

مقیاس هدف: حدود ۸٬۵۰۰ پرسنل در ۸۵۰ شعبه و کلینیک · محل استقرار: مرکز داده

مخزن کد: github.com/sjalilvand/rose-attendance · اکتبر ۲۰۲۶ (مهر ۱۴۰۵)